

Playbook: Failed Logon Burst (4625)

Playbook: Failed Logon Burst (4625)

****Date:**** 2025-11-11

****Owner:**** Gabriel Marquez

****MITRE ATT&CK:**** T1110 (Brute Force) — Tactic: Credential Access

Purpose

Detect bursts of failed Windows logons indicative of password guessing or brute-force activity. Validated with Windows Security event ingestion via the **System** integration.

Data Sources

- Windows Security event logs via ****System**** integration
- Data stream: ``system.security``
- Index pattern used in searches: ``logs-*`` (backed by ``data_stream.dataset: "system.security"``)

Detection (KQL — base filter for threshold rule)

`data_stream.dataset: "system.security" and winlog.event_id: 4625`

> Apply a ****threshold**** in the rule definition (e.g., `count ≥ 10` within 10 minutes per ``host.name`` or ``user.name``).

Rule Configuration (Elastic)

- ****Type:**** Threshold (on KQL query above)
- ****Group by:**** ``host.name`` (or ``user.name``)
- ****Threshold:**** `≥ 10` events in 10 minutes (tunable)
- ****Index patterns:**** ``logs-*``
- ****Schedule:**** Every 5 minutes
- ****Additional look-back:**** 1 minute
- ****Severity:**** High
- ****Risk score:**** 75
- ****Tags (optional):**** ``["MITRE:T1110","Brute Force","Credential Access"]``

Validation Steps (What was done)

1. Enabled Windows Security events via ****System**** integration (assigned to active Agent policy).
2. Verified ingestion in **Discover**:
 - ``data_stream.dataset: "system.security" AND winlog.event_id: 4625``
3. Generated test failures:
 - Login screen wrong password attempts
 - ``runas.exe /user:.\WrongUser cmd`` (exit code 1)
4. Confirmed events appearing with the above KQL; tuned threshold if needed.

Evidence (Artifacts)

- ``19_integration_system_security_added.png`` — System (Security) integration added
- ``20_discover_system_security_4625.png`` — 4625 events visible in Discover
- ``21_4625_event_json_sample.png`` — Representative JSON for 4625
- (If alerting rule enabled) ``22_4625_threshold_alerts.png`` — Alerts list showing burst
- (If alerting rule enabled) ``23_4625_alert_details.png`` — Alert details (counts, entity keys)

Response

- Identify source (e.g., IP, host), targeted account, and timing.
- Lock or reset accounts when appropriate; consider MFA enforcement.
- Add suppression or exception if a known noisy service is identified (reduce FP).

Reporting

- Summarize volume, accounts impacted, and window of activity.
- Map to **MITRE T1110** in Capstone Task 2 alignment and interview packet.